Mini-projet 4 : Sécurité des Réseaux et Tests d'Intrusion

Partie 4A : Configuration d'un firewall basique

1. Vérification de l'état du pare-feu:

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -L -v
[sudo] password for kali:
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source
on

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source
on

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source
on
```

Vérification des règles du pare-feu.

2. Définir les règles de base (politique par défaut):

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -P INPUT DROP

┌──(kali㉿kali)-[~]
└─$ sudo iptables -P OUTPUT ACCEPT

┌──(kali㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy DROP 1 packets, 76 bytes)
 pkts bytes target     prot opt in     out     source
on

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source
on

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source
on
```

Ajout des règles de base du pare-feu.

3. Autoriser le trafic SSH (pour l'accès à la VM si nécessaire) :

4. Autoriser le trafic loopback (pour le fonctionnement interne):

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -i lo -j ACCEPT

┌──(kali㉿kali)-[~]
└─$ sudo iptables -A OUTPUT -o lo -j ACCEPT
```

5. Autoriser le trafic entre les 3 VMs (pour faciliter les prochains parties) :

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -s 192.168.145.0/24 -j ACCEPT
```

Le réseau est ici en 192.168.145.0/24.

8. Vérification:

```
└─$ sudo iptables -L -v
Chain INPUT (policy DROP 8 packets, 608 bytes)
 pkts bytes target     prot opt in     out     source               destinati
on
    0     0 ACCEPT     tcp  --  any    any     anywhere             anywhere
              tcp dpt:ssh
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere

    2   253 ACCEPT     all  --  any    any     192.168.145.0/24     anywhere


Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destinati
on

Chain OUTPUT (policy ACCEPT 10 packets, 742 bytes)
 pkts bytes target     prot opt in     out     source               destinati
on
    0     0 ACCEPT     all  --  any    lo      anywhere             anywhere
```

Règles mises en place.

9. Tests:

```
C:\Users\naelo>ssh kali@192.168.145.131
ssh: connect to host 192.168.145.131 port 22: Connection refused

C:\Users\naelo>ssh kali@192.168.145.131
The authenticity of host '192.168.145.131 (192.168.145.131)' can't be established.
ED25519 key fingerprint is SHA256:vg1EMcM+kA5M207F5AF2Ewe6393sqs3iMIRPyYa9sBk.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.145.131' (ED25519) to the list of known hosts.
kali@192.168.145.131's password:
Linux kali 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
┌──(kali㉿kali)-[~]
└─$
```

Connexion SSH depuis la machine hôte réussie.

```
┌──(kali㉿kali)-[~]
└─$ ping 172.30.240.1
PING 172.30.240.1 (172.30.240.1) 56(84) bytes of data.
```

Impossible de ping la machine hôte.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.145.129
PING 192.168.145.129 (192.168.145.129) 56(84) bytes of data.
64 bytes from 192.168.145.129: icmp_seq=1 ttl=64 time=6.43 ms
64 bytes from 192.168.145.129: icmp_seq=2 ttl=64 time=0.587 ms
64 bytes from 192.168.145.129: icmp_seq=3 ttl=64 time=1.53 ms
64 bytes from 192.168.145.129: icmp_seq=4 ttl=64 time=0.534 ms
```

Ping réussi vers la deuxième VM.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.145.132
PING 192.168.145.132 (192.168.145.132) 56(84) bytes of data.
64 bytes from 192.168.145.132: icmp_seq=1 ttl=64 time=3.15 ms
64 bytes from 192.168.145.132: icmp_seq=2 ttl=64 time=0.576 ms
64 bytes from 192.168.145.132: icmp_seq=3 ttl=64 time=3.75 ms
64 bytes from 192.168.145.132: icmp_seq=4 ttl=64 time=0.672 ms
64 bytes from 192.168.145.132: icmp_seq=5 ttl=64 time=0.885 ms
```

Ping réussi vers la troisième VM.

Partie 4B : Mise en place et utilisation d'un IDS (Snort, Suricata).

2. Configuration de Snort (fichier snort.conf) :

```
-- setup the network addresses you
HOME_NET = 192.168.145.0/24
```

```
ips =
{
    -- use this to enable decoder and inspector alert
    enable_builtin_rules = true,

    -- use include for rules files; be sure to set yo
    -- note that rules files can include other rules
    -- (see also related path vars at the top of snor
    rules = 'include ' .. RULE_PATH .. '/*.rules',

    variables = default_variables
}
```

```
--alert_sfsocket = { }
alert_syslog = {
    facility = 'log_auth',
    level = 'info',
--unified2 = { }
```

Configuration du fichier snort.lua dans le cadre de l'utilisation de Snort 3 et non Snort 2.

3. Lancer Snort en mode détection :

```
                    total:      219     219
fast pattern groups
                to_server: 1
                to_client: 1
search engine (ac_bnfa)
                instances: 2
                 patterns: 438
            pattern chars: 2602
               num states: 1832
          num match states: 392
              memory scale: KB
              total memory: 71.2812
            pattern memory: 19.6484
         match list memory: 28.4375
         transition memory: 22.9453
appid: MaxRss diff: 2944
appid: patterns loaded: 300
pcap DAQ configured to passive.
FATAL: see prior 1 errors (0 warnings)
Fatal Error, Quitting..
```

Une erreur semble systématiquement arriver lors du lancement de snort.

Partie 4C : Scan de ports et de services avec Nmap

1. Scans de ports basiques (TCP SYN scan) :

```
┌──(kali㉿kali)-[/etc/snort]
└─$  nmap -sS 192.168.145.132

Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 06:43 EDT
Nmap scan report for 192.168.145.132
Host is up (0.00042s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
25/tcp   open  smtp
143/tcp  open  imap
587/tcp  open  submission
993/tcp  open  imaps
8080/tcp open  http-proxy
MAC Address: 00:0C:29:77:DB:76 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.52 seconds

┌──(kali㉿kali)-[/etc/snort]
```

Scan Nmap de la machine Kali victime.

2. Scan de ports spécifique :

```
┌──(kali㉿kali)-[/etc/snort]
└─$ nmap -p 22,80,443 192.168.145.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 06:44 EDT
Nmap scan report for 192.168.145.132
Host is up (0.0018s latency).

PORT    STATE  SERVICE
22/tcp  open   ssh
80/tcp  closed http
443/tcp closed https
MAC Address: 00:0C:29:77:DB:76 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

Scan des ports ssh, http et https de la machine Kali victime.

3. Scan des ports UDP :

```
┌──(kali㉿kali)-[/etc/snort]
└─$ nmap -sU 192.168.145.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 06:46 EDT
Nmap scan report for 192.168.145.132
Host is up (0.0014s latency).
All 1000 scanned ports on 192.168.145.132 are in ignored states.
Not shown: 1000 closed udp ports (port-unreach)
MAC Address: 00:0C:29:77:DB:76 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1088.43 seconds
```

Scan des ports UDP de la machine Kali victime, tous les ports sont fermés.

4. Détection de services (Service Version Detection) :

```
┌──(kali㉿kali)-[/]
└─$ nmap -sV 192.168.145.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 08:18 EDT
Nmap scan report for 192.168.145.132
Host is up (0.00026s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 10.2p1 Debian 2 (protocol 2.0)
25/tcp   open  smtp?
143/tcp  open  imap     Dovecot imapd
587/tcp  open  smtp     Postfix smtpd
993/tcp  open  ssl/imap Dovecot imapd
8080/tcp open  http     nginx
MAC Address: 00:0C:29:77:DB:76 (VMware)
Service Info: Host:  kali; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at h
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 165.45 seconds

┌──(kali㉿kali)-[/]
└─$
```

Scan des ports des services.

5. Scan de l'OS (Operating System Detection) :

```
┌──(kali㉿kali)-[/]
└─$ nmap -O 192.168.145.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 08:24 EDT
Nmap scan report for 192.168.145.132
Host is up (0.0027s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
25/tcp   open  smtp
143/tcp  open  imap
587/tcp  open  submission
993/tcp  open  imaps
8080/tcp open  http-proxy
MAC Address: 00:0C:29:77:DB:76 (VMware)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at http
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.96 seconds
```

Scan de l’OS, ici un Linux version 4.15 à 5 .19.

6. Combiner les options :

```
└$ nmap -sS -sV -O -p 1-65535 192.168.145.132

Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 08:28 EDT
Nmap scan report for 192.168.145.132
Host is up (0.0018s latency).
Not shown: 65529 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 10.2p1 Debian 2 (protocol 2.0)
25/tcp   open  smtp?
143/tcp  open  imap     Dovecot imapd
587/tcp  open  smtp     Postfix smtpd
993/tcp  open  ssl/imap Dovecot imapd
8080/tcp open  http     nginx
MAC Address: 00:0C:29:77:DB:76 (VMware)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: Host:  kali; OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect result
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 171.30 seconds
```

7. Analyse des résultats :

Nous pouvons observer que l'OS de la machine victime est un Linux version 4.15 à 5.19, nous pouvons observer que plusieurs ports sont ouverts en particulier les ports 22 et 8080 sur lesquels sont ouverts les services ssh et http qui peuvent servirent assez facilement de porte d'accès dans le cadre d'une attaque.

Nous pouvons aussi observer le nom de l'hôte et l'adresse MAC de la machine.

Partie 4D : Mise en place d'une attaque simple (scan de port) :

1.Scan de ports initial (reconnaissance) :

```
kali@kali: /
Session  Actions  Edit  View  Help
        RX packets 352  bytes 25240 (24.6 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 352  bytes 25240 (24.6 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

┌──(kali㉿kali)-[/]
└─$ nmap -sS -sV -p 1-65535 192.168.145.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-05 10:42 EDT
Nmap scan report for 192.168.145.129
Host is up (0.00064s latency).
Not shown: 65529 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 10.2p1 Debian 2 (protocol 2.0)
25/tcp   open  smtp?
143/tcp  open  imap     Dovecot imapd
587/tcp  open  smtp     Postfix smtpd
993/tcp  open  ssl/imap Dovecot imapd
8080/tcp open  http     nginx
MAC Address: 00:0C:29:4E:AF:96 (VMware)
Service Info: Host:  kali; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 176.04 seconds

┌──(kali㉿kali)-[/]
└─$
```

2. Analyse des résultats du scan :

Ici nous pouvons voir que plusieurs ports sont ouverts dont le port 22 avec le service ssh.

3. Mise en place de l'attaque (Exemple avec SSH) :

```
└─$ hydra -l kali -p kali 192.168.145.132 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-05 15:
03:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
 per task
[DATA] attacking ssh://192.168.145.132:22/
[22][ssh] host: 192.168.145.132   login: kali   password: kali
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-05 15:
03:44

┌──(kali㉿kali)-[/usr/share/wordlists]
```

Attaque de la machine victime avec les credentials kali kali.

4. Analyse des résultats de l'attaque et Production d'un rapport:

Afin d'attaquer la machine victime, nous avons tout d'abord commencé par réaliser via une machine attaquante dans le même réseau, un scan des ports de la machine victime via la commande nmap :

nmap -sS -sV -p 1-65535 192.168.145.1

Nous avons pu y observer que le port 22 sur lequel tournait le service ssh était ouvert et vulnérable à une attaque.

Nous avons pu ainsi tenter une attaque brute-force afin de trouver le mot de passe permettant de se connecter au service ssh.

Cela nous permet par la suite de se connecter en ssh à la machine et d'en prendre le contrôle, le compte utilisé pour la connexion étant le compte root de la machine.

Nous proposons dans un premier temps de mettre en place un pare-feu plus efficace empêchant un scan complet des ports par une machine dans le même réseau en mettant en place un système plus restrictif dans les protocoles d'entrées.

Ensuite nous proposons pour le service ssh, d'utiliser une clé plutôt qu'un mot de passe comme connexion afin de ne pas pouvoir compromettre la connexion ssh avec une attaque de type brute-force. De plus la connexion via ssh ne devrait s'effectuer avec le compte root afin d'empêcher un potentiel attaquant de prendre le contrôle de la machine avec le compte possédant les privilèges les plus élevés.